

UNIVERSITÉ DE MONCTON CAMPUS DE MONCTON

Faculté des sciences

Département Informatique

Devoir 3 : DNS Spoofing avec Ettercap

INFO4307

Cybersécurité

Oumar Leyti Ndiaye

A00228981

Session : Hiver2026

Introduction :

La sécurité des infrastructures réseau constitue aujourd'hui un enjeu majeur dans le domaine de l'informatique. Parmi les nombreuses menaces qui pèsent sur les systèmes d'information, les attaques visant le protocole DNS (Domain Name System) représentent un vecteur d'attaque particulièrement redoutable en raison de leur discrétion et de leur efficacité.

Le présent rapport porte sur la réalisation d'un travail pratique effectué dans le cadre du cours INFO4307 - Sujets avancés en informatique (Cybersécurité), portant sur l'attaque par usurpation DNS, communément appelée DNS Spoofing. Cette attaque consiste à intercepter les requêtes DNS émises par une machine victime et à lui retourner de fausses réponses, dans le but de la rediriger vers un site web contrôlé par l'attaquant, sans que celle-ci ne s'en aperçoive.

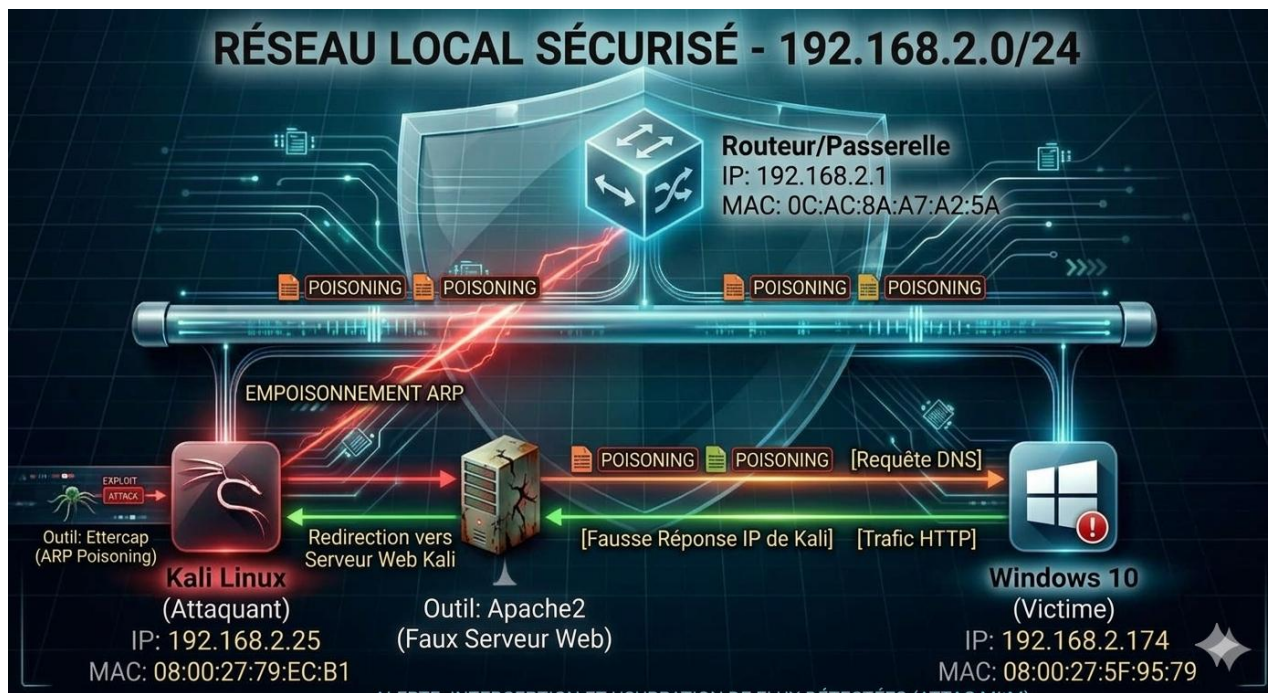
Pour mener à bien ce TP, un environnement virtuel a été mis en place, composé d'une machine attaquante sous Kali Linux et d'une machine victime sous Windows, toutes deux interconnectées au sein d'un réseau local. L'outil principal utilisé est Ettercap, un framework reconnu dans le domaine de la cybersécurité offensive, spécialisé dans les attaques de type man-in-the-middle.

Objectif du TP :

Ce travail pratique a pour objectif de comprendre et de démontrer le fonctionnement d'une attaque DNS Spoofing dans un environnement réseau contrôlé. Plus précisément, les objectifs sont les suivants :

- Configurer et utiliser l'outil Ettercap pour réaliser une attaque de type man-in-the-middle combinée à une usurpation DNS.
- Intercepter les requêtes DNS d'une machine victime et les rediriger vers une machine attaquante.
- Démontrer les risques liés à ce type d'attaque en redirigeant la victime vers une fausse page web.
- Analyser les résultats obtenus et proposer des contre-mesures adaptées pour se protéger contre ce type d'attaque.

Topologie :



Machine	Rôle	Adresse IP	Adresse MAC
Kali Linux	Attaquant	192.168.2.25	08:00:27:79:EC:B1
Windows	Victime	192.168.2.174	08:00:27:5F:95:79
Passerelle	Routeur/Gateway	192.168.2.1	0C:AC:8A:A7:A2:5A

Présentation des outils utilisés :

1. Ettercap

Ettercap est un outil open-source dédié aux attaques de type man-in-the-middle sur les réseaux locaux. Il permet d'intercepter, analyser et manipuler le trafic réseau en temps réel. Dans le cadre de ce TP, Ettercap a été utilisé pour réaliser l'empoisonnement ARP ainsi que l'usurpation DNS via son plugin intégré dns_spoof. Il est disponible en mode graphique et en mode ligne de commande.

2. Apache2

Apache2 est un serveur web open-source très répandu. Dans ce TP, il a été utilisé sur la machine Kali Linux pour héberger une fausse page web (index.html) vers laquelle la victime

est redirigée lors de l'attaque DNS Spoofing. Il a été démarré via la commande : ***service apache2 start.***

Tâche 1 : DNS SPOOFNG

Étape 1 : Modification du fichier **etter.conf**

La première étape consiste à modifier le fichier de configuration d'Ettercap situé à `/etc/ettercap/etter.conf` via la commande :

gedit /etc/ettercap/etter.conf

Deux modifications importantes ont été effectuées dans ce fichier. Premièrement, les valeurs de **ec_uid** et **ec_gid** ont été remplacées par **zéro**. Ces deux paramètres définissent respectivement l'identifiant utilisateur et l'identifiant de groupe sous lesquels Ettercap s'exécute. En les mettant à zéro, on accorde à Ettercap les privilèges root, ce qui est indispensable pour intercepter le trafic réseau, manipuler les paquets et effectuer l'empoisonnement ARP. Sans ces privilèges, Ettercap ne serait pas en mesure d'exécuter l'attaque.

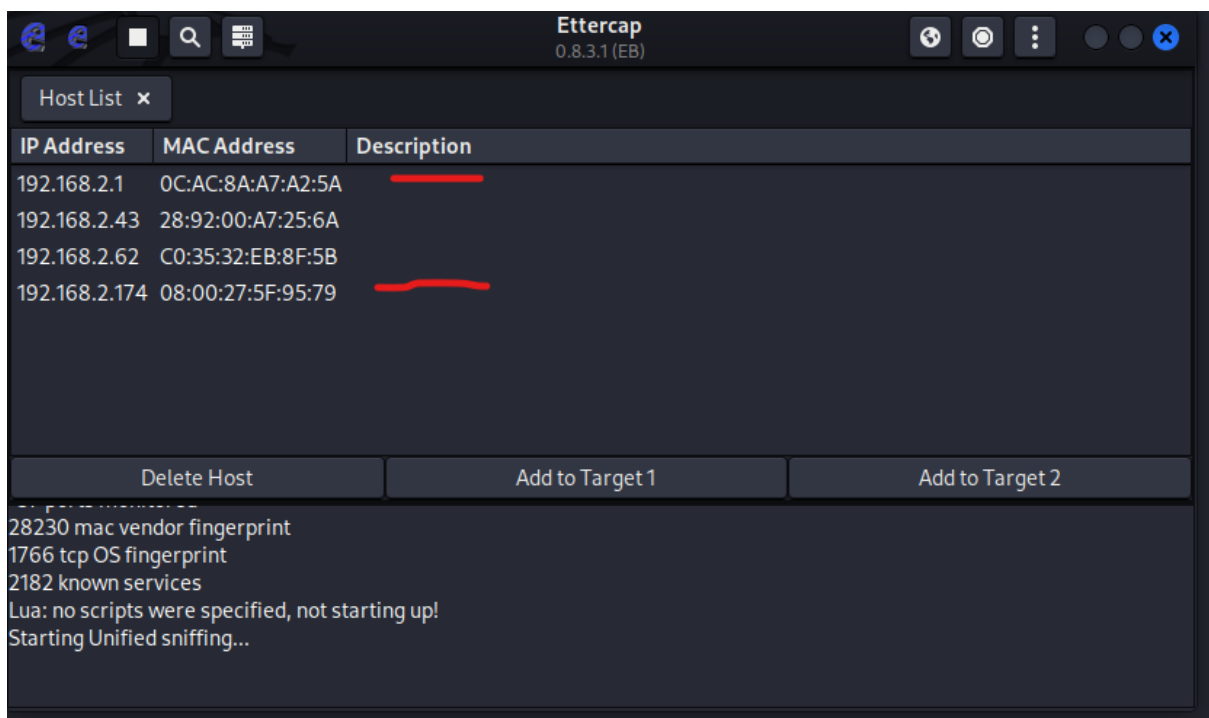
Deuxièmement, les quatre lignes de règles **iptables** ont été décommentées en supprimant le symbole **#** devant chacune d'elles. Ces règles permettent à Ettercap de rediriger les paquets réseau interceptés vers ses propres ports afin de les analyser et de les modifier. Sans cette configuration, Ettercap ne pourrait pas agir en tant que proxy transparent entre la victime et la passerelle.

Étape 2 : Démarrage de la machine victime Windows

La machine virtuelle Windows a été démarrée sous Oracle VirtualBox en mode pont (Bridge). Cette configuration réseau est essentielle car elle permet à la machine virtuelle d'être visible sur le même réseau physique que la machine Kali Linux, condition indispensable pour que l'attaque fonctionne. Son adresse IP a été récupérée via la commande `ipconfig` dans l'invite de commandes Windows. L'adresse obtenue est **192.168.2.174**.

Étape 3 : Ouverture d'Ettercap, sniffing et configuration des cibles

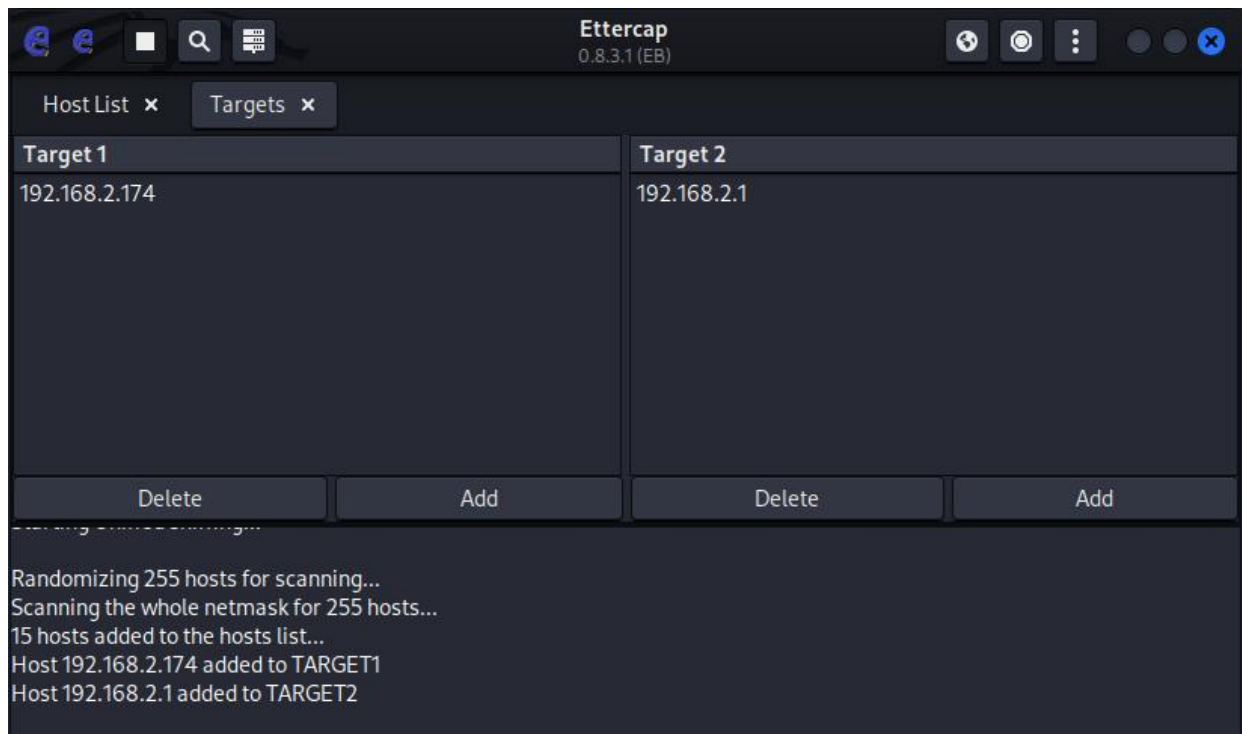
Ettercap a été ouvert en mode graphique via la commande ***sudo ettercap -G***. L'interface réseau **eth0** a été sélectionnée car c'est celle qui est connectée au réseau local 192.168.2.0/24. Le **sniffing** a ensuite été lancé via **Sniff** → **Unified Sniffing**, ce qui permet à Ettercap d'intercepter tous les paquets qui transitent sur le réseau. Un scan des hôtes a été effectué via **Hosts** → **Scan for hosts**, permettant de découvrir toutes les machines actives sur le réseau.



Concernant la configuration des cibles, la machine victime Windows (192.168.2.174) a été ajoutée en Target 1 car c'est elle dont on veut intercepter le trafic DNS. La passerelle (192.168.2.1) a été ajoutée en Target 2 car dans un réseau local, c'est elle qui joue le rôle d'intermédiaire entre les machines du réseau et les serveurs DNS externes. Lorsqu'une machine veut résoudre un nom de domaine, elle envoie sa requête DNS vers la passerelle, qui la transmet ensuite au serveur DNS configuré. En se positionnant entre la victime et la passerelle grâce à

L'ARP Poisoning, Ettercap peut intercepter ces requêtes DNS et y répondre avec de fausses informations avant qu'elles n'atteignent le vrai serveur DNS.

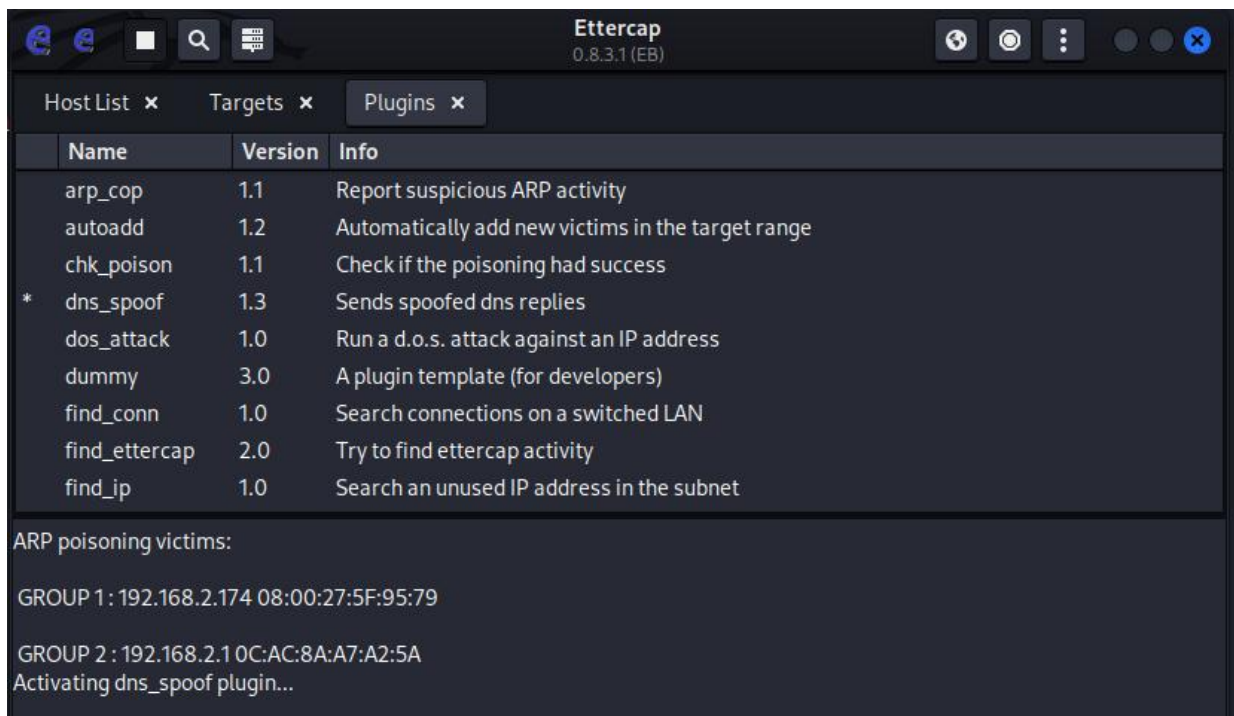
L'adresse IP de la passerelle a été identifiée via la commande `ip route`, qui a retourné 192.168.2.1 comme passerelle par défaut du réseau



Étape 4 : Activation de l'ARP Poisoning et Activation du plugin dns_spoof

L'attaque ARP Poisoning a été lancée via le menu Mitm → ARP Poisoning. L'option Sniff remote connections a été cochée afin de permettre l'interception du trafic entre la victime et la passerelle. Cette technique consiste à envoyer de fausses réponses ARP à la victime et à la passerelle afin d'associer l'adresse MAC de Kali aux adresses IP des deux cibles, redirigeant ainsi tout leur trafic vers la machine attaquante.

Le plugin dns_spoof a été activé via le menu Plugins → Manage the plugins. Un double-clic sur dns_spoof a permis de l'activer, confirmé par l'apparition d'une étoile à gauche du plugin dans la liste.



Étape 5 : Modification du fichier etter.dns

Le fichier /etc/ettercap/etter.dns a été modifié afin d'y ajouter les règles de redirection DNS. Les lignes suivantes ont été ajoutées :

```
55 # IPv6 support. Therefore the IPv6 specific examples has been #
56 # commented out to avoid ettercap throwing warnings during startup. #
57 # #
58 #####
59
60
61 # vim:ts=8:noexpandtab
62 #
63 microsoft.com A 192.168.2.25
64 *.microsoft.com A 192.168.2.25
65 www.microsoft.com PTR 192.168.2.25
~
~
~
```

L'objectif de cette étape est de définir les règles que le plugin dns_spoof utilisera pour répondre aux requêtes DNS de la victime. Lorsque la machine victime demandera l'adresse IP de microsoft.com, Ettercap interceptera cette requête et retournera l'adresse IP de la machine Kali (192.168.2.25) au lieu de la vraie adresse IP de Microsoft.

La signification de chaque ligne est la suivante :

- microsoft.com A 192.168.2.25 : toute requête DNS de type A (IPv4) pour le domaine microsoft.com sera redirigée vers 192.168.2.25.
- *.microsoft.com A 192.168.2.25 : toute requête DNS pour n'importe quel sous-domaine de microsoft.com (www, cdn, mail, etc.) sera également redirigée vers 192.168.2.25.

Étape 6 : Création de la fausse page web et démarrage d'Apache2

Une page web simple contenant le message « TP DNS Spoofing » a été créée sur la machine Kali Linux et placée dans le répertoire `/var/www/html/index.html`. Le service Apache2 a ensuite été démarré via la commande `service apache2 start`. Son statut a été vérifié via `service apache2 status`, confirmant qu'il est bien actif (active running).

```
Session Actions Éditer Vue Aide
<html>
    <body>
        <h1> TP DNS Spoofing </h1>
    </body>
</html>
~
```

```
(leyti002@kali)~]
$ sudo service apache2 start

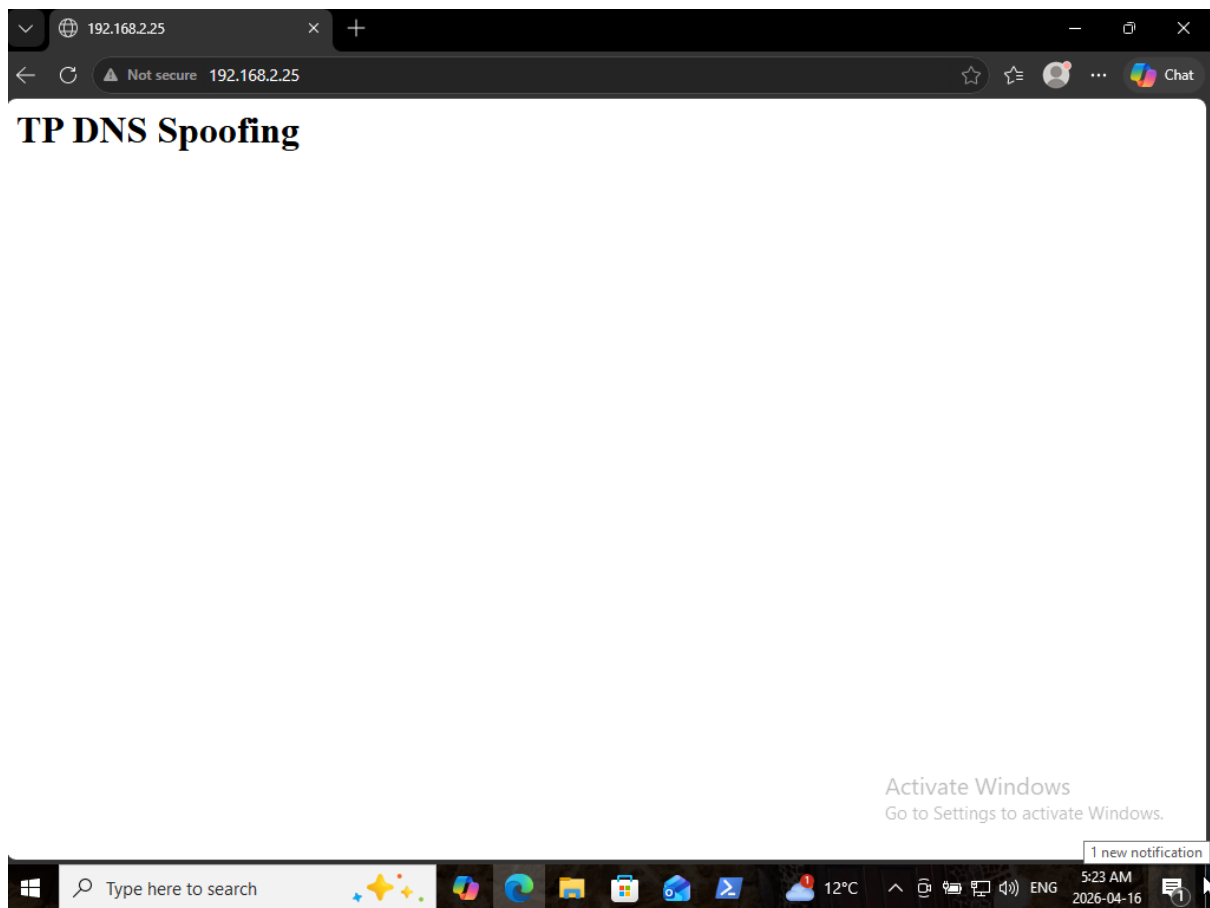
(leyti002@kali)~]
$ sudo service apache2 status
● apache2.service - The Apache HTTP Server
   Loaded: loaded (/usr/lib/systemd/system/apache2.service; disabled; preset: disabled)
   Active: active (running) since Thu 2026-04-16 20:32:16 ADT; 40s ago
 Invocation: 322026dbe7064660a715db55dec46076
    Docs: https://httpd.apache.org/docs/2.4/
   Process: 2187 ExecStart=/usr/sbin/apachectl start (code=exited, status=0/SUCCESS)
   Main PID: 2203 (apache2)
     Tasks: 7 (limit: 23790)
   Memory: 22.2M (peak: 23M)
      CPU: 259ms
   CGroup: /system.slice/apache2.service
           └─2203 /usr/sbin/apache2 -k start
             └─2206 /usr/sbin/apache2 -k start
               └─2207 /usr/sbin/apache2 -k start
                 └─2208 /usr/sbin/apache2 -k start
                   └─2209 /usr/sbin/apache2 -k start
                     └─2210 /usr/sbin/apache2 -k start
                       └─2211 /usr/sbin/apache2 -k start

avr 16 20:32:16 kali systemd[1]: Starting apache2.service - The Apache HTTP Server ...
avr 16 20:32:16 kali apachectl[2202]: AH00558: apache2: Could not reliably determine the server's fully qualified domain name, using 127.0.1.1. Set the 'ServerName' directi
avr 16 20:32:16 kali systemd[1]: Started apache2.service - The Apache HTTP Server.

(leyti002@kali)~]
```

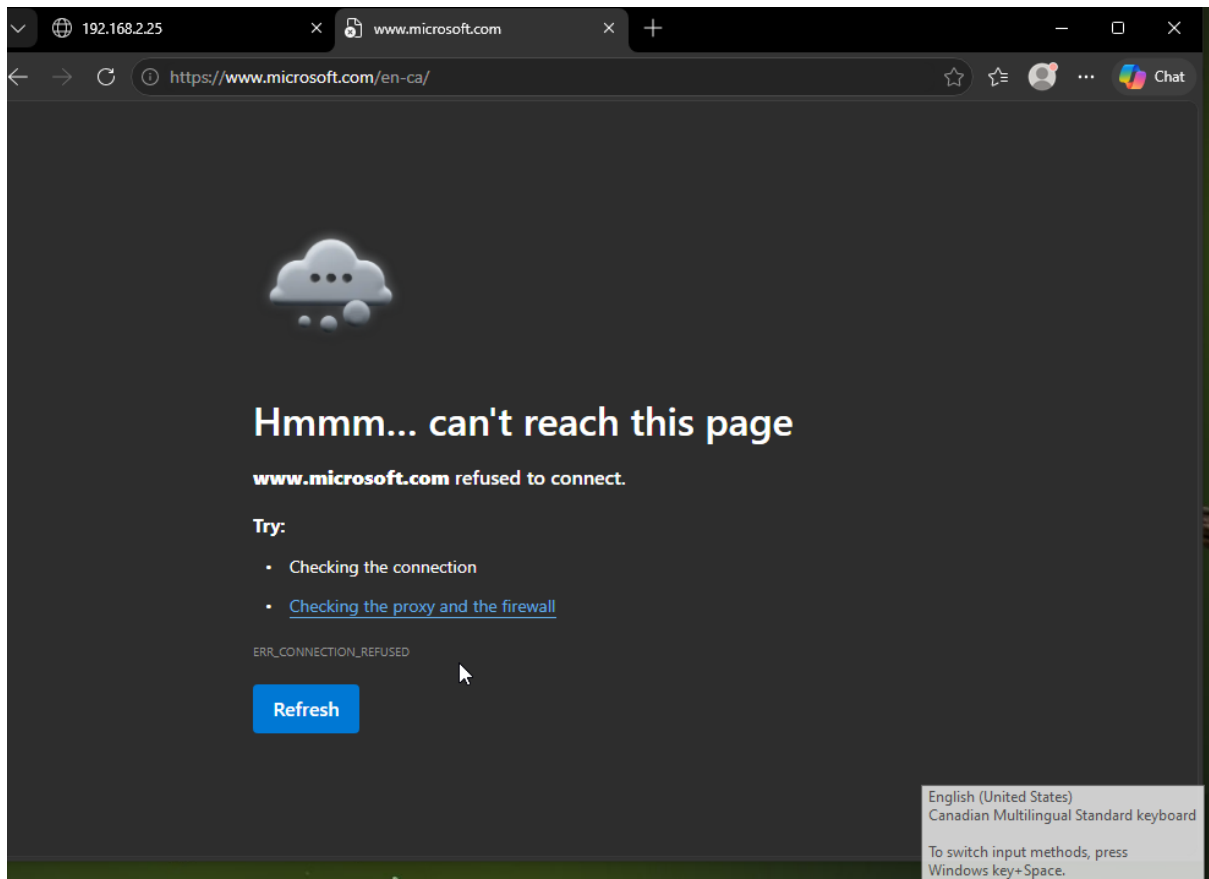
Étape 8 : Test d'accès à la page web depuis la machine victime

Depuis le navigateur de la machine victime Windows, l'adresse IP de la machine Kali (192.168.2.25) a été saisie directement dans la barre d'adresse. La page « TP DNS Spoofing » s'est affichée correctement, confirmant que le serveur Apache2 est bien accessible depuis la machine victime.



Étape 9 : Test du DNS Spoofing

Depuis le navigateur de la machine victime Windows, l'URL `www.microsoft.com` a été saisie. Ettercap a intercepté la requête DNS et a retourné l'adresse IP de la machine Kali (192.168.2.25) à la place de la vraie adresse IP de Microsoft. Le navigateur a affiché une erreur de connexion refusée (ERR_CONNECTION_REFUSED), ce qui confirme que le DNS Spoofing a bien fonctionné : la requête a bien été redirigée vers 192.168.2.25. L'erreur est due au fait que le navigateur force le protocole HTTPS, alors que le serveur Apache2 ne dispose pas de certificat SSL valide pour microsoft.com.



Étape 10 : Analyse des résultats dans Ettercap (mode graphique)

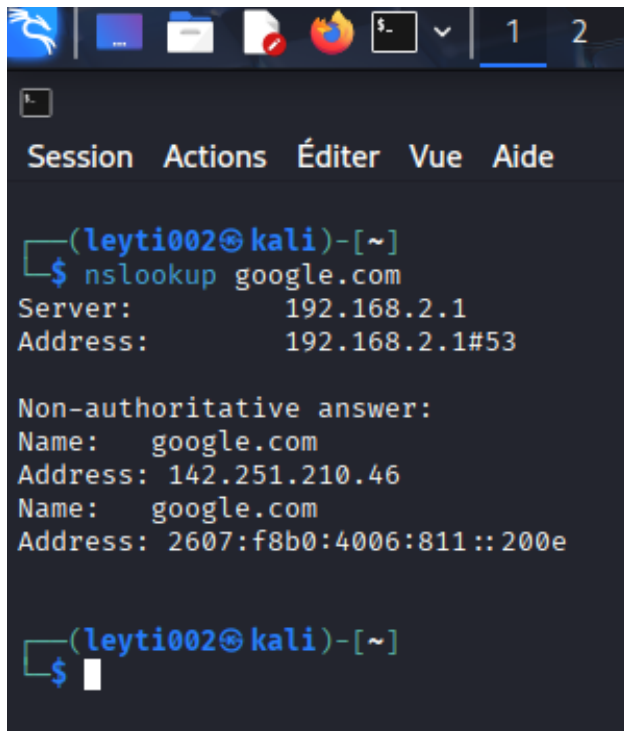
La console d'Ettercap affiche en temps réel toutes les requêtes DNS interceptées et redirigées. On peut observer les messages suivants :

```
dns_spoof: A [www.microsoft.com] spoofed to  
[192.168.2.25] TTL [3600s]  
  
dns_spoof: A [cdn-dynmedia-1.microsoft.com] spoofed to  
[192.168.2.25] TTL [3600s]  
  
dns_spoof: A [browser.events.data.microsoft.com] spoofed  
to [192.168.2.25] TTL [3600s]
```

Ces messages confirment que toutes les requêtes DNS liées à microsoft.com ont été interceptées et redirigées vers la machine attaquante 192.168.2.25.

Étape 12 : Redirection vers un autre site web

L'étape 18 du TP consiste à répéter l'attaque en redirigeant le trafic vers un autre site web réel. Le fichier etter.dns a été modifié pour remplacer l'adresse IP de Kali par l'adresse IP de Google (142.251.210.46), obtenue via la commande `nslookup google.com`.



```
(leyti002@kali)-[~]
$ nslookup google.com
Server:      192.168.2.1
Address:     192.168.2.1#53

Non-authoritative answer:
Name:   google.com
Address: 142.251.210.46
Name:   google.com
Address: 2607:f8b0:4006:811::200e

(leyti002@kali)-[~]
$
```

Ainsi, lorsque la victime tente d'accéder à `www.microsoft.com`, elle est redirigée vers les serveurs de Google au lieu de la machine Kali. La console Ettercap confirme cette redirection :

```
dns_spoof: A [www.microsoft.com] spoofed to
[142.251.210.46] TTL [3600s]
```

```
# NOTE: Default DNS TTL is 3600s (1 hour). All
#
# NOTE: IPv6 specific do not work because etter
#       IPv6 support. Therefore the IPv6 specif
#       commented out to avoid ettercap throwin
#
#####

# vim:ts=8:noexpandtab
#
microsoft.com A 142.251.210.46
*.microsoft.com A 142.251.210.46
```

```
Session Actions Éditer Vue Aide
* |----->| 100.00 %
3 hosts added to the hosts list ...
ARP poisoning victims:
GROUP 1 : 192.168.2.1 0C:AC:8A:A7:A2:5A
GROUP 2 : 192.168.2.174 08:00:27:5F:95:79
Starting Unified sniffing ...

Text only Interface activated ...
Hit 'h' for inline help

Activating dns_spoof plugin ...
dns_spoof: A [www.microsoft.com] spoofed to [192.168.2.25] TTL [3600 s]
dns_spoof: A [www.microsoft.com] spoofed to [192.168.2.25] TTL [3600 s]
dns_spoof: A [cdn-dynmedia-1.microsoft.com] spoofed to [192.168.2.25] TTL [3600 s]
dns_spoof: A [www.microsoft.com] spoofed to [192.168.2.25] TTL [3600 s]
dns_spoof: A [www.microsoft.com] spoofed to [192.168.2.25] TTL [3600 s]
dns_spoof: A [www.microsoft.com] spoofed to [192.168.2.25] TTL [3600 s]
dns_spoof: A [browser.events.data.microsoft.com] spoofed to [192.168.2.25] TTL [3600 s]
```

Étape 13 : Arrêt de l'attaque

L'attaque a été arrêtée en appuyant sur q dans le terminal Ettercap. Sur la machine victime, le cache DNS a été vidé via la commande `ipconfig /flushdns` afin de rétablir le fonctionnement normal du DNS.

Questions théoriques :

Question 20 : Signification de `ec_uid` et `ec_gid`

Les valeurs `ec_uid` et `ec_gid` définissent respectivement l'identifiant utilisateur (User ID) et l'identifiant de groupe (Group ID) sous lesquels Ettercap s'exécute. En mettant ces deux valeurs à zéro, on indique à Ettercap de s'exécuter avec les privilèges de l'utilisateur root (UID=0, GID=0). Cela est nécessaire dans le cadre de cette attaque, car la manipulation des paquets réseau, l'empoisonnement ARP et la redirection des ports via iptables nécessitent des droits d'administrateur. Sans ces privilèges, Ettercap ne serait pas en mesure d'intercepter le trafic réseau ni d'injecter de fausses réponses DNS.

Question 21 : Signification des règles iptables

Les règles iptables décommentées dans `etter.conf` permettent à Ettercap de rediriger les paquets réseau interceptés vers les ports appropriés pour les analyser et les modifier. Plus précisément, ces règles configurent des règles de NAT (Network Address Translation) dans la table de pré-routerage (PREROUTING) du pare-feu Linux. Elles redirigent le trafic TCP intercepté par la machine attaquante vers le port local d'Ettercap. Sans ces règles, Ettercap ne pourrait pas agir en tant que proxy transparent entre la victime et la passerelle, et l'attaque man-in-the-middle ne fonctionnerait pas correctement.

Question 22 : Protection contre le DNS Spoofing

Plusieurs mesures peuvent être mises en place pour se protéger contre une attaque de type DNS Spoofing :

- DNSSEC (DNS Security Extensions) : ajoute une signature cryptographique aux réponses DNS, permettant au client de vérifier l'authenticité des réponses reçues et de détecter toute tentative de falsification.
- HTTPS et HSTS : force les navigateurs à utiliser uniquement des connexions chiffrées et à rejeter les certificats non valides, rendant l'attaque visible pour l'utilisateur.
- VPN : chiffre tout le trafic réseau, empêchant l'attaquant d'intercepter les requêtes DNS.
- DNS over HTTPS (DoH) ou DNS over TLS (DoT) : chiffre les communications DNS, rendant l'interception difficile.
- Surveillance du trafic ARP : déployer des outils de détection d'empoisonnement ARP comme arpwatch pour détecter les anomalies dans les tables ARP du réseau.
- Segmentation du réseau : isoler les machines sensibles sur des VLANs séparés afin de limiter la portée d'une éventuelle attaque man-in-the-middle.

Tâche 2 : Gestion et réponses aux incidents de sécurité

Scénario 1 : Correctif déployé sans test

Le gros problème ici c'est que Marc a déployé un patch en vitesse sans le tester, juste avant de partir en vacances. Résultat : personne ne peut se connecter et lui il est dans l'avion.

La première chose à faire c'est d'essayer de joindre Marc pour comprendre exactement ce qu'il a fait. En parallèle, Suzana doit contacter un autre admin ou son supérieur pour ne pas gérer ça seule. La solution la plus rapide c'est de désinstaller le patch et revenir à la version d'avant, ce qu'on appelle un rollback. Une fois que tout remarche, on analyse ce qui s'est passé pour ne pas revivre la même situation.

Pour que ça n'arrive plus, l'entreprise doit mettre des règles claires :

1. Aucun déploiement en production sans tests au préalable dans un environnement de test.
2. Toujours avoir un plan de rollback prêt avant de toucher à quoi que ce soit en prod.
3. Deux personnes doivent valider avant tout changement important.
4. Tous les changements doivent être documentés pour qu'un autre admin puisse s'y retrouver en cas d'absence.
5. On évite de déployer un correctif critique la veille de ses vacances.

Scénario 2 : Carte SD infectée

Ce qui s'est passé ici c'est qu'un employé a branché la carte SD de l'entreprise sur son PC personnel qui était infecté. En la remettant dans une machine du boulot, le malware s'est retrouvé sur le réseau de l'organisation.

Dès qu'on détecte ça, la première réaction c'est d'isoler la machine infectée du réseau immédiatement. On ne laisse pas le malware se propager aux autres postes. Ensuite on identifie de quel type de malware il s'agit avec un antivirus ou un outil d'analyse. Selon la gravité, on nettoie la machine ou on la réinstalle complètement. On vérifie aussi si d'autres machines ont été touchées en regardant les logs réseau.

Pour savoir comment le malware s'est propagé, il faut analyser les logs du réseau et des machines. Un bon antivirus centralisé avec des alertes en temps réel aurait pu détecter ça plus vite.

Pour éviter que ça se reproduise :

6. L'entreprise doit interdire clairement l'utilisation de supports personnels sur les machines du travail.
7. Les ports USB peuvent être désactivés ou contrôlés via une solution de gestion des endpoints.
8. Tout support amovible doit être scanné automatiquement avant d'être utilisé.
9. Les employés doivent être sensibilisés à ce genre de risques, parce que souvent ils ne réalisent pas le danger.

Scénario 3 : Menace de hacktivistes

On sait qu'on va être attaqués mais on ne sait pas comment. C'est stressant mais ça laisse quand même le temps de se préparer.

Voici la méthodologie à suivre étape par étape :

Étape 1 — Évaluer la menace : chercher des infos sur ce groupe, qui ils sont, ce qu'ils ont déjà fait, leurs méthodes habituelles. Ça aide à savoir où concentrer les efforts de défense.

Étape 2 — Faire un audit complet de l'infrastructure : vérifier les pare-feux, les accès distants, les mises à jour de tous les systèmes, et les mots de passe des comptes admin. Tout ce qui est exposé sur internet et qui n'est pas nécessaire doit être désactivé.

Étape 3 — Renforcer la surveillance : alertes en temps réel sur l'IDS, analyse plus fréquente des logs, et surveiller les réseaux sociaux pour voir si des infos circulent sur l'attaque.

Étape 4 — Préparer un plan de réponse aux incidents pour les scénarios les plus probables : DDoS, défacement du site, intrusion dans les systèmes. Les contacts des équipes techniques et des autorités doivent être à jour.

Étape 5 — Informer les équipes internes de la menace et leur donner des consignes claires, surtout sur le phishing qui accompagne souvent ce genre d'attaque.

Partie 2 : Liste des mesures de sécurité

Pour les réseaux :

Les attaques les plus courantes sur les réseaux sont l'ARP Poisoning, le DNS Spoofing, les DDoS et les attaques man-in-the-middle.

- ARP Poisoning : activer le Dynamic ARP Inspection (DAI) sur les switches managés et configurer des entrées ARP statiques pour les machines importantes. Des outils comme arpwatck permettent de détecter les anomalies dans les tables ARP.
- DNS Spoofing : déployer DNSSEC pour garantir l'authenticité des réponses DNS. Utiliser DNS over HTTPS (DoH) ou DNS over TLS (DoT) pour chiffrer les échanges DNS.
- DDoS : des solutions comme Cloudflare peuvent absorber le trafic malveillant. Mettre en place un filtrage de trafic en amont.
- Man-in-the-Middle : utiliser des VPN pour chiffrer les communications, activer HTTPS et HSTS sur tous les services web.
- De manière générale : segmenter le réseau en VLANs pour limiter la portée d'une attaque, déployer un IDS/IPS comme Snort ou Suricata, et maintenir les équipements réseau à jour.

Pour les serveurs :

Les risques principaux sur les serveurs sont l'exploitation de vulnérabilités, les attaques par force brute et les ransomwares.

- Exploitation de vulnérabilités : toujours garder les systèmes à jour et effectuer des audits de sécurité réguliers.
- Force brute : pour SSH, désactiver les connexions par mot de passe et utiliser des clés cryptographiques. Limiter le nombre de tentatives de connexion.
- Ransomwares : faire des sauvegardes régulières stockées hors ligne. Appliquer le principe du moindre privilège.
- De manière générale : configurer un pare-feu pour n'ouvrir que les ports nécessaires, centraliser et analyser les logs, désactiver tous les services inutiles.

Pour les applications :

Les attaques les plus fréquentes sur les applications web sont l'injection SQL, le XSS et le CSRF.

- Injection SQL : utiliser des requêtes préparées et valider toutes les entrées utilisateur côté serveur.
- XSS (Cross-site scripting) : échapper correctement les données affichées dans les pages web et mettre en place une politique CSP.
- CSRF (Cross-site request forgery) : utiliser des tokens de validation dans tous les formulaires et vérifier l'origine des requêtes.
- De manière générale : déployer un Web Application Firewall (WAF), effectuer des tests de pénétration réguliers, et former les développeurs aux bonnes pratiques OWASP.

Références :

1. NIST. (2018). *Framework for Improving Critical Infrastructure Cybersecurity*. <https://www.nist.gov/cyberframework>
2. OWASP. (2021). *OWASP Top Ten*. <https://owasp.org/www-project-top-ten/>
3. SANS Institute. (2023). *Incident Handler's Handbook*. <https://www.sans.org/white-papers/33901/>
4. Cisco. (2023). *What Is Network Segmentation?* <https://www.cisco.com/c/en/us/products/security/what-is-network-segmentation.html>
5. Cloudflare. (2024). *What is DNS Security?* <https://www.cloudflare.com/learning/dns/dns-security/>
6. Microsoft. (2023). *Security best practices*. <https://learn.microsoft.com/en-us/azure/security/fundamentals/best-practices-and-patterns>
7. CISA. (2023). *Ransomware Guide*. <https://www.cisa.gov/stopransomware/ransomware-guide>
8. ANSSI. (2022). *Guide des bonnes pratiques de l'informatique*. <https://www.ssi.gouv.fr/guide/bonnes-pratiques-de-linformatique/>

Observations générales :

Durant la réalisation de ce TP, plusieurs observations importantes ont été notées.

L'attaque DNS Spoofing avec Ettercap fonctionne efficacement sur un réseau local. Les requêtes DNS de la machine victime ont bien été interceptées et redirigées vers la machine attaquante, comme en témoignent les messages affichés dans la console Ettercap. La redirection vers un autre site web réel (Google) a également été démontrée avec succès.

Cependant, nous avons constaté que les navigateurs modernes (Edge, Chrome) disposent de mécanismes de protection tels que HTTPS et HSTS qui empêchent l'affichage d'une fausse page web lorsque le site cible utilise ces protocoles. Le navigateur a affiché une erreur de connexion refusée, ce qui montre que ces protections sont efficaces contre ce type d'attaque.

Après l'arrêt de l'attaque, le cache DNS de la machine victime a été vidé via la commande `ipconfig /flushdns` afin de rétablir le fonctionnement normal du DNS.

Les expériences ont-elles permis d'atteindre les objectifs ?

Oui, les expériences ont pleinement permis d'atteindre les objectifs fixés. Nous avons démontré concrètement le fonctionnement de l'attaque DNS Spoofing et son exploitation pour intercepter et falsifier les requêtes DNS d'une machine victime. La console Ettercap a confirmé en temps réel que toutes les requêtes DNS liées à microsoft.com ont été interceptées et redirigées vers la machine attaquante.

Contre-mesures proposées :

Suite à cette expérience, nous proposons les contre-mesures suivantes pour se protéger contre une attaque DNS Spoofing :

- Déployer DNSSEC sur les serveurs DNS de l'organisation pour garantir l'authenticité des réponses DNS.
- Activer HTTPS et HSTS sur tous les sites web de l'organisation.
- Utiliser un VPN pour chiffrer l'ensemble du trafic réseau des utilisateurs.
- Surveiller le trafic ARP et mettre en place des alertes en cas d'anomalie.
- Former les utilisateurs à reconnaître les avertissements de sécurité des navigateurs.
- Segmenter le réseau en VLANs pour limiter la portée d'une attaque.

Conclusion :

Ce travail pratique nous a permis de comprendre en profondeur le fonctionnement d'une attaque DNS Spoofing et ses implications en matière de sécurité. Grâce à l'outil Ettercap, nous avons pu démontrer qu'il est relativement simple pour un attaquant positionné sur le même réseau local d'intercepter et de falsifier les réponses DNS d'une machine victime.

Cette expérience souligne l'importance de déployer des mécanismes de protection robustes tels que DNSSEC, HTTPS, HSTS et les VPNs pour se prémunir contre ce type d'attaque, qui bien que partiellement limitée par les navigateurs modernes, demeure une menace réelle dans de nombreux environnements réseau peu sécurisés.